Evolve Edge

MVP Requirements Document

Version: 1.1 **Date:** 19/03/2026 **Status:** Final Draft

Document Status Overview

Section	Status
Definitions	COMPLETED
Scope	COMPLETED
Functional Requirements	COMPLETED
Web App	COMPLETED
Mobile App	OUT OF SCOPE
Admin Portal	COMPLETED
Back-end	COMPLETED
Non-functional Requirements	COMPLETED
Milestones	COMPLETED
Platforms	COMPLETED
Location, languages & culture	COMPLETED
Security	COMPLETED
Legal & compliance	COMPLETED
Performance	COMPLETED
Reliability	COMPLETED

Section	Status
Costs	COMPLETED
Scalability	COMPLETED
Logging & auditing	COMPLETED
Analytics & reporting	COMPLETED
Content management	COMPLETED
Technology	COMPLETED
Integrations	COMPLETED

1. Definitions

COMPLETED

- **Web App:** The web application being developed.
- **Admin Portal:** The web application being developed to administer the system.
- **Back-end:** The cloud-based services and database being developed.
- **Usage:** The number of users, the activity of those users, and the data stored by those users.
- **User types:** Standard User, Organization Admin, Super Admin (System).
- **Tenant:** An organization that subscribes to and uses the Evolve Edge platform.
- **Workload:** A structured compliance task — either an Assessment or an Audit.
- **Assessment:** A workload used to evaluate and improve an organization's compliance maturity score.
- **Audit:** A formal workload that produces evidence-based pass/fail compliance findings.
- **Compliance Rule Engine:** The system component that maps uploaded documents to regulations and frameworks.
- **AI Analysis Engine:** The AI/LLM-driven component that interprets documents and produces compliance insights.
- **RBAC:** Role-Based Access Control — the permission model governing user actions.

- **MFA:** Multi-Factor Authentication.

2. Scope

COMPLETED

In Scope (MVP)

- **Web App:** The primary user interface for the system.
- **Identity & Authentication:** User registration (email/password) and email verification. Login/logout and password reset. Optional MFA via authenticator apps or email OTP. Social Login (Google and Microsoft).
- **Architecture & Management:** Organization & Multi-Tenant Architecture. Role-Based Access Control (RBAC) and Group Hierarchy System. User and Profile Management.
- **Document Ingestion System:** Supports PDF, DOCX, and TXT formats; processes uploads for use in assessments/audits.
- **Simple AI Analysis Engine:** Handles compliance analysis and risk scoring.
- **Compliance Rule Engine:** Library for regulations and frameworks (e.g., PCI DSS, HIPAA, SOC2).
- **Reporting and Alerting System:** Downloadable PDF reports and risk alerts (Low, Medium, High, Critical).
- **Assessments:** Checking and improving compliance scores; outputs maturity evaluations and risk recommendations.
- **Audits:** Evidence-based evaluations to verify compliance; outputs pass/fail findings.
- **Dashboards & Feeds:** Compliance overview and activity feeds with commenting and liking.

Out of Scope

- Mobile Applications
- Enterprise SSO (Okta, Azure AD)
- Custom compliance framework builder
- Advanced workflow automation
- AI training customization

- Regulatory submission automation
- Real-time collaboration features
- Chat functionality
- Multi-organization users
- Advanced analytics dashboards
- Slack, Microsoft Teams, and SMS notifications

3. Functional Requirements

COMPLETED

3.1 Web Application COMPLETED

3.1.1 Identity & Authentication

- **Sign-Up:** Requires first/last name, email, password, organization name, country, and industry type. Supports social login (Google, Microsoft).
- **Login:** Email/Password, Social Login, and optional MFA (Authenticator app or Email OTP).
- **Organization Setup:** New users create accounts with organization validation and 2FA. Organizations select specific regulations and frameworks to adhere to.
- **Password Reset:** Via email link with a 24-hour expiry token.
- **Email Verification:** Required before accessing the platform; resend functionality provided.
- **Session Management:** JWT-based sessions; idle timeout after 60 minutes.

3.1.2 Document Management

- Organizations maintain a library of documents (PDF, DOCX, TXT).
- Documents are processed upon upload for use in assessments/audits.
- Documents can be linked to specific regulations/frameworks.
- Document library supports tagging, search, and filtering.
- Maximum file size: 25 MB per document.
- Documents display upload date, status (processing/ready/error), linked frameworks, and uploaded-by user.

3.1.3 Workloads (Assessments & Audits)

Assessments:

- Used to check/improve compliance scores.
- Outputs include maturity evaluations, risk highlights, and remediation recommendations via LLM prompt.
- Maturity scoring: 1–5 scale per framework domain.
- Risk categorization: Low, Medium, High, Critical.

Audits:

- Evidence-based evaluations to determine if specific standards are met.
- Formal pass/fail output with detailed findings.
- Evidence attachments linked to each control/requirement.

Workflow States for both: Draft → Ready to Run → Running → Completed → Archived.

3.1.4 Dashboard & Feeds

Compliance Overview:

- Overall compliance score and trend indicator (up/down vs. last assessment).
- Framework-specific scores (e.g., HIPAA: 78%, PCI DSS: 92%).
- Active risk alerts panel (Low/Medium/High/Critical count).
- Recent reports list with download links.

Activity Feed:

- Shows document uploads, report generation, score changes, and user actions.
- Supports favoriting (star), hierarchical commenting (threaded), and "likes."
- Feed filters: by type, by user, by date range.

3.1.5 User & Profile Management

Admins:

- Manage users: add, edit, deactivate/archive users.
- Assign roles and groups to users.
- Invite external users (e.g., PEN testers) via email invitation with expiry.

- View user activity logs within their organization.

Users:

- Manage own profile: avatar, display name, notification preferences, MFA settings.
- View own activity history.

Account Closure:

- Users with permission can close accounts.
- Data is archived for 30 days before permanent deletion/anonymization.
- Accounts can be reopened within the 30-day window.

3.1.6 Notifications

- In-app notifications for: workload completions, new risk alerts, document processing status, user invitations.
- Email notifications for: account events (sign-up, password reset), workload completions, high/critical risk alerts.
- User-configurable notification preferences (opt-in/opt-out per category).

3.1.7 Search

- Global text search bar accessible from all pages.
- Searchable content: documents, reports, risk findings, frameworks.
- Admin-only: user search.
- Filters: by date range, framework, content type.
- Results ranked by relevance with highlighted matching terms.

3.1.8 Payments & Subscriptions

- Subscription plans managed via Stripe.
- Plan selection during organization sign-up.
- In-app billing portal for invoice history, plan upgrades/downgrades, and payment method management.
- Stripe-hosted checkout for initial payment capture.
- Failed payment handling: email notification and grace period (7 days) before access suspension.

3.2 Mobile App OUT OF SCOPE

Not included in MVP.

3.3 Admin Portal COMPLETED

The Admin Portal is a separate, secured web interface for Evolve Edge system administrators to manage the global platform.

3.3.1 Authentication & Access

- Separate login URL from the main web app (e.g., admin.evolveedge.ai).
- MFA is mandatory for all admin accounts — cannot be bypassed.
- Auto-logout after 15 minutes of inactivity.
- IP allowlist: Admin Portal access restricted to approved IP ranges.
- All login attempts (successful and failed) are logged to the audit trail.

3.3.2 Organization Management

- View all registered organizations (tenant list).
- Filter/search by name, country, industry, subscription plan, and status.
- View organization details: user count, active workloads, subscription plan, billing status.
- Ability to suspend or reactivate an organization account.
- View organization-level audit logs.
- Manually trigger account anonymization (for compliance or legal requests).

3.3.3 User Management

- Search and view all users across all organizations.
- View user profile, organization membership, role assignments, and activity history.
- Ability to lock/unlock a user account.
- Ability to force a password reset for any user.
- View and export user audit logs.

3.3.4 Regulation & Framework Management

- Create, edit, publish, and archive compliance frameworks (e.g., PCI DSS, HIPAA, SOC2, ISO 27001).
- Define framework domains, controls, and requirements.

- Manage standard document templates associated with each framework.
- Version control for frameworks (track changes; organizations remain on their current version until admin migrates them).

3.3.5 Workload Template Management

- Create and manage assessment and audit workload templates.
- Define LLM prompts for each template type (with version tracking).
- Specify required document types for each workload template.
- Enable/disable workload templates globally or per-organization.

3.3.6 System Configuration

- Manage global settings: account closure retention period (default: 30 days), unverified user cleanup period (default: 30 days), session idle timeout (default: 60 min).
- Manage email templates for system notifications.
- Configure feature flags for gradual feature rollouts.

3.3.7 Monitoring & Analytics Dashboard

- Live metrics: active users (last 24h), new sign-ups (today/this week), active workloads running, reports generated.
- System health indicators: API response time trend, AI engine queue depth, error rate.
- Subscription metrics: active paid plans, trial conversions, churned organizations.

3.3.8 Audit Logs

- Searchable, filterable log of all admin actions (who, what, when, IP address).
- Immutable log entries — no admin can edit or delete audit log records.
- Exportable to CSV for compliance and legal review.
- Minimum retention: 2 years.

3.4 Back-end COMPLETED

The back-end consists of cloud-hosted APIs, services, and automated background processes.

3.4.1 API Architecture

- RESTful API design following OpenAPI 3.0 specification.
- All endpoints require JWT bearer token authentication (except public auth endpoints).
- API versioning via URL prefix (e.g., /api/v1/).
- Rate limiting: 100 requests/min per authenticated user; 20 requests/min for unauthenticated endpoints.
- All responses in JSON format with consistent error structure: { error_code, message, details }.

3.4.2 Authentication Service

- Issues JWT access tokens (15-min expiry) and refresh tokens (7-day expiry, stored in HTTP-only cookies).
- Handles MFA validation (TOTP via authenticator app; OTP via email).
- Social login token exchange (Google OAuth2, Microsoft OAuth2).
- Manages session revocation (logout, forced logout by admin, password change).

3.4.3 Document Processing Service

- Accepts file uploads (PDF, DOCX, TXT) up to 25 MB.
- Validates file type by MIME type and content inspection (not just extension).
- Stores files in encrypted cloud storage (AWS S3 with AES-256 at-rest encryption).
- Extracts text using PDF parser (e.g., pdfplumber) and DOCX parser (python-docx).
- Queues extracted text for AI analysis via message queue (AWS SQS or Redis Queue).
- Updates document status in real time: Uploading → Processing → Ready / Error.

3.4.4 AI Compliance Engine

- Receives extracted document text and workload configuration (framework, LLM prompt template).
- Calls OpenAI API (GPT-4o or equivalent) with structured prompt to evaluate compliance.
- Returns structured JSON output: compliance score, maturity level, risk findings (category, severity, description, remediation recommendation).

- Stores AI analysis results in database linked to the originating workload.
- Handles OpenAI API errors with retry logic (exponential backoff, max 3 retries).
- Tracks OpenAI API token consumption per organization for cost monitoring.

3.4.5 Report Generation Service

- Generates PDF reports from completed workload analysis results.
- Report types: Compliance Summary Report, Detailed Findings Report, Remediation Action Plan.
- PDF rendering using WeasyPrint or similar library with branded templates.
- Reports stored in AWS S3 with pre-signed download URLs (1-hour expiry).
- Report metadata stored in database (generated date, generated by, linked workload, download count).

3.4.6 Notification Service

- Sends transactional emails via AWS SES or SendGrid.
- In-app notification storage: notifications table in PostgreSQL with read/unread status.
- Supports notification types: workload complete, risk alert triggered, document processed, user invited, account events.
- Email templates managed via CMS; rendered server-side before sending.

3.4.7 Subscription & Billing Service

- Integrates with Stripe via official SDK.
- Handles subscription creation, upgrades, downgrades, and cancellations via Stripe webhooks.
- Syncs subscription status to internal database on every webhook event.
- Enforces plan limits (e.g., max documents, max users, max workloads) at API level.
- Generates and stores invoice metadata for admin portal reporting.

3.4.8 Background Jobs & Scheduled Tasks

- Unverified User Cleanup: Runs daily; deletes users who have not verified email within 30 days.
- Closed Account Anonymization: Runs daily; anonymizes all data for accounts closed >30 days.

- Scheduled jobs use cron-based scheduling (AWS EventBridge or Celery Beat).
- All job executions logged with status (success/failure/partial), duration, and affected record count.

3.4.9 Multi-Tenancy & Data Isolation

- All database tables include an organization_id foreign key for tenant data separation.
- All API queries are scoped to the authenticated user's organization_id — enforced at ORM/service layer.
- Cross-tenant data access is prohibited; any attempt triggers an audit log entry and returns 403.
- Admin Portal API uses a separate admin role that bypasses organization scoping with full audit logging.

4. Non-Functional Requirements COMPLETED

4.1 Milestones COMPLETED

All requirements are included in the MVP milestone unless explicitly stated otherwise. Target launch: Q3 2026.

Phase	Description	Duration	Target Date
Phase 1	Foundation: Auth, org setup, user & profile management, RBAC	4 weeks	Week 4
Phase 2	Core AI Engine: Document ingestion, compliance rule engine, AI analysis	6 weeks	Week 10
Phase 3	Workloads & Reporting: Assessments, audits, PDF report generation, dashboard	5 weeks	Week 15
Phase 4	Admin Portal & Back-end Services: Admin portal, billing integration, notifications	4 weeks	Week 19
Phase 5	QA, Security & Launch Prep: Full PEN test, bug fixes, performance tuning, staging	4 weeks	Week 23
Launch	Production Deployment & Hypercare	1 week	Week 24

> **Key Milestone Gates:**
> - End of Phase 2: Internal demo of AI compliance engine with sample documents.
> - End of Phase 3: Beta access opens to 5 design-partner organizations.
> - End of Phase 4: Feature freeze; no new features added after this point.
> - End of Phase 5: All high/medium PEN test findings resolved; sign-off from stakeholders required before launch.

4.2 Platforms COMPLETED

- **Web App:** Responsive web application; supported browsers: Chrome (latest 2 versions), Firefox (latest 2 versions), Edge (latest 2 versions), Safari 16+.
- **Admin Portal:** Web-based; same browser support as Web App. Desktop-only layout (no mobile optimization required).
- **Mobile App:** Out of scope for MVP.
- **Minimum screen resolution supported:** 1280 × 720px (desktop). Mobile breakpoint for web app: 375px.

4.3 Location, Languages & Culture COMPLETED

- **Locations:** Global support — no geographic restrictions on user sign-up.
- **Languages:** English (US) for MVP. Application copy, labels, error messages, and email templates must all use American English. Architecture must support internationalization (i18n) from the start using a strings/translation file structure to enable future language additions without code changes.
- **Date Format:** ISO 8601 (YYYY-MM-DD) for storage; displayed as MM/DD/YYYY (US format) in the UI for MVP.
- **Time:** Displayed in the user's local timezone, detected via browser. Stored in UTC.
- **Number Format:** US standard (e.g., 1,000.00).
- **Currencies:** USD is the default and only currency for MVP billing.
- **RTL Support:** No — not required for MVP.

4.4 Security COMPLETED

4.4.1 Encryption

- In Transit: TLS 1.2 minimum; TLS 1.3 preferred. All HTTP traffic redirected to HTTPS.

- At Rest: AES-256 encryption for all non-public data. Encryption keys managed by the cloud host (AWS KMS).
- Database: Encryption at rest enabled on all RDS/Aurora instances.

4.4.2 Authentication Security

- Passwords: Minimum 10 characters; must include uppercase, lowercase, number, and special character. Hashed using bcrypt (min. 12 rounds).
- Brute Force Protection: Account lockout after 5 consecutive failed login attempts; lockout duration 15 minutes, with admin override.
- Session Tokens: JWT tokens signed with RS256; refresh tokens stored in HTTP-only, Secure, SameSite=Strict cookies.
- MFA: TOTP via authenticator app (RFC 6238); backup codes provided on setup (8 single-use codes).

4.4.3 Application Security

- OWASP Top 10: All development must address OWASP Top 10 vulnerabilities as a baseline standard.
- Input Validation: All user inputs validated server-side; parameterized queries enforced to prevent SQL injection.
- XSS Prevention: All user-generated content sanitized and escaped; Content Security Policy (CSP) headers enforced.
- CSRF Protection: CSRF tokens required for all state-changing requests (POST, PUT, PATCH, DELETE).
- Dependency Scanning: Automated scanning of all third-party dependencies via Dependabot or Snyk; critical vulnerabilities must be patched within 14 days.
- SAST: Static Application Security Testing integrated into CI/CD pipeline (e.g., Bandit for Python, ESLint security plugin for JS).

4.4.4 Infrastructure Security

- DDoS Protection: IP blocking, throttling, and DNS protection via Cloudflare or AWS Shield Standard.
- Secrets Management: All secrets and API keys stored in AWS Secrets Manager. No secrets in source code repositories or environment variable files. Key rotation every 90 days (automated where supported).

- Network: All services deployed in private VPC subnets; only load balancer exposed to public internet. Database not publicly accessible.
- Admin Portal: Accessible only via IP allowlist; enforced at network/WAF level.

4.4.5 Penetration Testing

- A full independent PEN test (external vendor) is required before production launch.
- Scope: Web App, Admin Portal, and all public-facing APIs.
- All Critical and High-risk findings must be resolved before launch. Medium-risk findings must have a documented remediation plan.
- Re-test required after remediation of Critical/High findings.

4.5 Legal & Compliance COMPLETED

4.5.1 Required Legal Policies

- Terms of Service: Covers acceptable use, service limitations, IP ownership, and liability disclaimers.
- Privacy Policy: Details data collected, purpose of collection, data sharing (third-party processors), user rights, and contact details for data requests.
- Cookie Policy: Lists all cookies used (functional, analytics, third-party), their purpose, and duration. Must be linked from the cookie consent banner.

4.5.2 Cookie Consent

- A cookie consent banner is required on first visit for all new users.
- Users must be able to accept all, reject non-essential, or customize cookie preferences.
- Consent preferences stored in a persistent cookie; not re-prompted on subsequent visits until preferences expire (12 months).

4.5.3 Compliance Readiness

- HIPAA: Data handling, access controls, audit logging, and BAA (Business Associate Agreement) capability must meet HIPAA requirements. Organizations in healthcare verticals should be prompted to execute a BAA.
- PCI DSS (SAQ-A level): Cardholder data never stored on Evolve Edge servers; all payment processing handled entirely by Stripe. No PAN data transits Evolve Edge systems.

- CCPA (Future): Architecture must support "right to delete" (account anonymization) and data export functionality — both already in scope for MVP.
- GDPR (Future): Architecture must support right to access, right to erasure, and data portability — to be fully implemented in a post-MVP release targeting EU expansion.

4.5.4 Data Retention

- Active user data: Retained for the life of the subscription.
- Closed accounts: Anonymized after 30 days (configurable by super admin).
- Audit logs: Minimum 2 years retention.
- Uploaded documents: Retained for the life of the organization account; deleted upon anonymization.
- Backups: Daily backups retained 7 days; weekly backups retained 4 weeks.

4.5.5 Data Processing Agreements

- A Data Processing Agreement (DPA) must be available for enterprise customers upon request.
- Third-party sub-processors (OpenAI, AWS, Stripe, SendGrid) must be listed in the Privacy Policy as sub-processors.

4.6 Performance COMPLETED

4.6.1 Page Load & API Response Targets

- Initial page load (LCP): < 3 seconds on a standard broadband connection.
- API Response Times: p50 < 100ms, p80 < 300ms, p90 < 500ms (excluding AI analysis endpoints).
- AI Analysis Endpoints: Typically < 30 seconds; 95th percentile < 60 seconds.
- Time to First Byte (TTFB): < 200ms.

4.6.2 User Feedback for Long Operations

- Any operation that takes > 3 seconds must display a visible loading/progress indicator.
- Any operation expected to take > 5 seconds must support background processing with a notification on completion (user does not need to wait on screen).

- AI analysis runs asynchronously; users are notified via in-app notification and email when complete.

4.6.3 Optimization Standards

- Static assets (JS, CSS, images) served via CDN with cache headers set for minimum 30-day browser caching.
- Images: WebP format preferred; lazy loading required for all below-the-fold images.
- Code splitting and lazy loading required for Next.js frontend to reduce initial bundle size.
- Database queries: All frequently-run queries must use indexed columns; N+1 query patterns prohibited.
- Caching: Redis used for session data, frequently-read configuration data, and rate limiting counters.

4.7 Reliability COMPLETED

4.7.1 Uptime Target

- 99% uptime SLA (including planned maintenance windows).
- Planned maintenance must be communicated to users with a minimum 48 hours notice via in-app banner and email.
- Maintenance windows scheduled outside of 9am–6pm EST business hours.

4.7.2 Backup & Recovery

- Daily automated backups: Retained for 7 days.
- Weekly automated backups: Retained for 4 weeks.
- Database backups stored in a separate AWS region from the primary deployment.
- A fully documented restore procedure must be created and tested before production launch.
- RTO (Recovery Time Objective): < 4 hours.
- RPO (Recovery Point Objective): < 24 hours (daily backup cycle).

4.7.3 Health Checks & Monitoring

- All services expose a /health endpoint returning service status, version, and upstream dependency status.

- Infrastructure monitoring via AWS CloudWatch (or equivalent): CPU, memory, disk, queue depth, error rates.
- Alerting: PagerDuty or equivalent configured for critical alerts (uptime < 99%, error rate > 1%, AI engine queue depth > 50).
- On-call rotation must be defined before production launch.

4.7.4 Fault Tolerance

- Critical service dependencies (OpenAI API, Stripe, AWS SES) must have graceful degradation: if unavailable, queue jobs for retry rather than returning hard errors to users.
- AI analysis jobs: Retry up to 3 times with exponential backoff before marking as failed and notifying user.
- Circuit breaker pattern implemented for all external API calls.

4.8 Costs COMPLETED

4.8.1 Infrastructure Cost Targets

- Target: < $200/month for up to 1,000 active users.
- Scaling target: < $0.20/month per user above 1,000 users (unit cost reduces as user count increases).
- AI costs (OpenAI API) are variable and excluded from the infrastructure target; tracked separately and factored into subscription pricing.

4.8.2 Recommended Architecture for Cost Efficiency

- Compute: Serverless (AWS Lambda) or containerized workloads (ECS Fargate) — avoid always-on EC2 instances for workloads with variable demand.
- Database: AWS RDS PostgreSQL (managed) with auto-scaling storage; start with db.t3.medium.
- Storage: AWS S3 for documents and reports; lifecycle rules to move infrequently accessed documents to S3-IA after 90 days.
- CDN: AWS CloudFront or Cloudflare Free/Pro tier for static asset delivery.
- Caching: AWS ElastiCache (Redis) — single-node for MVP; upgrade to cluster for scale.
- Email: AWS SES — extremely low cost per email (~$0.10 per 1,000 emails).

- AI: OpenAI API pay-per-use; cost-per-workload must be estimated and validated during Phase 2 development.

4.8.3 Cost Monitoring

- AWS Cost Explorer with budget alerts: alert when monthly spend exceeds 80% of target budget.
- Per-organization AI cost tracking to inform future usage-based pricing tiers.

4.9 Scalability COMPLETED

4.9.1 Design Principles

- The platform must experience no degradation in performance or uptime as usage grows.
- Architecture must support horizontal scaling for both web/API services and AI processing workloads.
- All services designed to be stateless (session state stored in Redis/database, not in-process).

4.9.2 Auto-Scaling

- Web/API tier: Configured with auto-scaling policies (scale out when CPU > 70% or request latency > 500ms; scale in after 10 minutes below threshold).
- AI processing tier: Worker pool scaled based on SQS/Redis queue depth (scale out when queue depth > 10 jobs; scale in when queue is empty for 5 minutes).

4.9.3 Database Scalability

- PostgreSQL with read replicas for read-heavy workloads (reporting queries, dashboard data).
- Connection pooling via PgBouncer to manage database connection limits under load.
- Database schema designed with tenant partitioning in mind for future migration to partitioned tables if needed.

4.9.4 Multi-Tenancy Scalability

- Shared-database, shared-schema model for MVP (all tenants in one database with organization_id scoping).

- Architecture documented to support future migration to dedicated schemas or databases for enterprise tenants if required.

4.10 Logging & Auditing COMPLETED

4.10.1 Application Logging

- All application logs emitted in structured JSON format (timestamp, level, service, request_id, user_id, organization_id, message, context).
- Log levels: DEBUG (dev only), INFO, WARNING, ERROR, CRITICAL.
- Troubleshooting logs retained for a minimum of 7 days; 30-day retention recommended.
- Log aggregation via AWS CloudWatch Logs or ELK Stack (Elasticsearch, Logstash, Kibana).
- Error alerting: ERROR and CRITICAL level logs trigger alerts via PagerDuty or equivalent.

4.10.2 Audit Trail

- All user-initiated actions that modify data must be recorded in an immutable audit log table.
- Required audit events:
  - Authentication events: Login (success/failure), logout, MFA enable/disable, password change, account lockout.
  - User management: User invited, user role changed, user deactivated, user deleted.
  - Organization events: Org settings changed, subscription changed, org suspended.
  - Workload events: Workload created, started, completed, archived.
  - Document events: Document uploaded, document deleted.
  - Admin events: All Admin Portal actions (framework created/edited, system settings changed).
  - Report events: Report generated, report downloaded.
- Audit log schema: { id, timestamp, event_type, actor_user_id, actor_ip_address, organization_id, target_entity_type, target_entity_id, changes_json }.
- Audit records retained for a minimum of 2 years.
- Audit logs are read-only via API — no delete or update endpoints exposed.

- Exportable to CSV for compliance reviews.

4.11 Analytics & Reporting COMPLETED

4.11.1 User-Facing Analytics (Google Analytics / GA4)

- GA4 implemented on the web app for all authenticated page views and key user-initiated events.
- Custom events tracked (minimum): workload_started, workload_completed, document_uploaded, report_downloaded, user_invited, plan_upgraded.
- PII must not be sent to Google Analytics; user IDs sent as anonymized hashed identifiers only.

4.11.2 Backend / Product Analytics

- API usage metrics (requests per endpoint, response times, error rates) tracked via application monitoring (AWS CloudWatch or Datadog).
- Per-organization metrics tracked internally: document count, workload count, reports generated, AI token consumption.
- This data is used for internal product decisions and future usage-based pricing.

4.11.3 Error Tracking

- Sentry (or equivalent) integrated for both frontend (Next.js) and backend (FastAPI) to capture and alert on unhandled exceptions.
- Error grouping and alerting configured; new error types alert the development team immediately.

4.11.4 Admin Analytics Dashboard

The Admin Portal must include a live analytics dashboard showing:

- Live metrics: Active users (last 24h), new sign-ups (today / this week / this month).
- Workload metrics: Active workloads running now, workloads completed today, AI engine queue depth.
- Content metrics: Documents uploaded today, reports generated today.
- Subscription metrics: Total active paid organizations, trial-to-paid conversion rate (last 30 days), churned organizations (last 30 days).
- System health: API p95 response time, error rate (last 1h), uptime (last 30 days).

4.12 Content Management COMPLETED

4.12.1 Static Assets

- All static assets (JavaScript bundles, CSS, images, fonts) served via CDN (AWS CloudFront or Cloudflare).
- Assets versioned using content hashing in filenames to enable aggressive long-term browser caching.
- Cache-Control headers set: max-age=31536000, immutable for versioned assets.

4.12.2 Dynamic / Configurable Content

The following content must be configurable via a CMS without requiring code redeployment:

- Compliance framework definitions and regulation metadata.
- Standard document templates associated with frameworks.
- LLM prompt templates for assessment and audit workload types.
- Email notification templates.
- In-app onboarding content (tooltips, help text, welcome messages).
- Marketing/landing page content (if hosted within the same platform).

4.12.3 Recommended CMS

- Headless CMS: Contentful, Sanity, or Strapi (self-hosted on AWS for cost efficiency).
- CMS accessed only by Evolve Edge admin users — not exposed to end tenants.
- CMS content delivered via CDN-cached API calls; cache invalidated on content publish.

4.12.4 Asset Storage Budget

- Storing and serving all static and dynamic assets must not exceed $100/month (separate from general infrastructure costs).
- Storage: AWS S3 + CloudFront; estimated cost well below threshold for MVP traffic volumes.

4.13 Technology COMPLETED

4.13.1 Recommended Technology Stack

Frontend:

- Framework: Next.js 14+ (App Router) — React-based SSR/SSG for performance and SEO.
- Language: TypeScript.
- UI Library: Tailwind CSS + shadcn/ui component library.
- State Management: Zustand or React Query (TanStack Query) for server state.
- Forms: React Hook Form + Zod for validation.

Backend:

- Framework: FastAPI (Python 3.12+) — async, high-performance REST API.
- ORM: SQLAlchemy 2.0 with Alembic for database migrations.
- Task Queue: Celery + Redis for background job processing.
- AI Integration: OpenAI Python SDK (GPT-4o model); prompt templates versioned in CMS.
- PDF Generation: WeasyPrint or ReportLab for compliance report PDF rendering.

Database:

- Primary: PostgreSQL 15+ (AWS RDS or Aurora Serverless v2).
- Cache / Queue Broker: Redis 7+ (AWS ElastiCache).
- File Storage: AWS S3.

Infrastructure:

- Cloud Provider: Amazon Web Services (AWS).
- Compute: AWS ECS Fargate (containerized) or AWS Lambda (serverless functions for lightweight endpoints).
- CDN: AWS CloudFront or Cloudflare Pro.
- DNS & DDoS: Cloudflare (proxied DNS for DDoS protection and WAF).
- Secrets: AWS Secrets Manager.
- Monitoring: AWS CloudWatch + Sentry + (optional) Datadog.
- IaC: Terraform for all infrastructure provisioning.
- CI/CD: GitHub Actions — automated test, lint, build, and deploy pipelines.
- Containerization: Docker + docker-compose for local development.

4.14 Integrations COMPLETED

Integration	Provider	Purpose	Priority
Payments	Stripe	Subscription billing, invoicing, payment method storage	MVP
AI / LLM	OpenAI API (GPT-4o)	Compliance analysis, risk scoring, remediation generation	MVP
Email (Transactional)	AWS SES or SendGrid	Account emails, notifications, alerts	MVP
Address Lookup	Google Places API or Loqate	Global address autocomplete at sign-up	MVP
Authentication (Social)	Google OAuth2, Microsoft OAuth2	Social login for end users	MVP
Analytics	Google Analytics 4 (GA4)	User behaviour tracking	MVP
Error Tracking	Sentry	Frontend + backend exception monitoring	MVP
DDoS / WAF	Cloudflare	DNS, DDoS protection, Web Application Firewall	MVP
Infrastructure	Amazon Web Services (AWS)	Hosting, storage, database, compute, CDN	MVP
Secrets Management	AWS Secrets Manager	API keys and credentials management	MVP
SMS Notifications	Twilio	SMS alerts (High/Critical risk)	Post-MVP
Enterprise SSO	Okta / Azure AD	Enterprise single sign-on	Post-MVP
Collaboration	Slack / MS Teams	Notification delivery to team channels	Post-MVP